Standard: SECURITY-POL00005-STN00011
Driver: Jason Joy
Classification: Internal
Version 12.0

Network Security Standard

1. Overview

The purpose of this Standard is to define required controls for Adobe networking devices. This includes two broad classes of infrastructure:

- **Security devices**, such as firewalls, VPN gateways, network proxies, secure edge gateways, and remote access gateways
- **Network devices** such as routers, switches, load balancers, and wireless access points

When the Standard references **Devices**, this rule applies to both security devices and network devices.

2. Scope

This Standard applies to devices on any Adobe owned and controlled network. While the main audience is teams responsible for core network and network security devices at Adobe, it is also important for teams planning their own infrastructure deployments to factor in the significant overhead of maintaining compliance and accountability to this Standard.

This Standard applies whether the deployment model is physical, virtualized or private cloud. Public cloud security is generally addressed by Uniform Cloud Security Standard,. This Standard will apply in any other Adobe-managed environment, including devices that connect Adobe private networks to public cloud networks.

3. Statement

3.1 All Adobe Workers

3.1.1 Adobe workers are prohibited from deploying infrastructure or workarounds intended to bypass Adobe's centrally managed controls as set forth in this Standard. Exceptions must be documented and approved as set forth in Section 5.

3.1.2 Adobe workers are prohibited from interfering with Adobe networks as this may compromise the security or availability of Adobe resources. For example, the use of wireless jammers or overflowing the network is prohibited. If this such action is done intentionally, disciplinary action may be taken.

3.1.3 Adobe workers must not disclose private IP addresses and routing information to unauthorized parties, either directly or programmatically.

3.1.4 Security has authority to order networks, hosts, or external services to be disconnected or blocked from the Adobe network without notice if they are believed to pose an immediate threat to data security.

Contents

1. Overview
2. Scope
3. Statement
   3.1 All Adobe Workers
   3.2 Device Owners
   3.3 Requirements Specific to FedRAMP Environments refer to FedRAMP Environment Protection Standard
   3.4 Requirements Specific to Cardholder Environments refer to Cardholder Data Protection Standard
4. Definitions
5. Responsibilities
6. Governing Policy
7. References
8. Document Properties
9. Document History

3.2 Device Owners

3.2.1 Device Owners are responsible for correct configuration and auditability of all devices according to the sections that follow. Device Owners are responsible for requesting formal exceptions to any variation from the Standard. The Standard Owner is responsible only for reviewing and documenting decisions regarding exceptions to this Standard.

3.2.2 Logical Access and Authentication

- User accounts that can access the device must be configured and managed in compliance with the Logical Access Account Standard and Authentication Standard.
- Device external interfaces must not respond to external connection requests (for example, pings, trace routes, SNMP, or HTTPS) from non-Adobe networks without approval from security.
- Administrative access must be limited to authorized Adobe subnets. Administrative access from the internet is prohibited.
- Administrative access must be enabled only through encrypted protocols (for example, SSH, HTTPS, SFTP). Unencrypted protocols are not allowed (for example, telnet, FTP, SMTP, TFTP).
- Where MFA is not supported, local account passwords must be rotated every 90 days. If supported, the device must use MFA and not store credentials.
- Automation tools must use a unique account for logging and the account credentials must be changed every 90 days.
- User Accounts for device access:
  - Where technically feasible, the default username must be deleted and changed.
  - Local system accounts must be disabled or deleted.
  - Session timeouts must be set to ten minutes (600 seconds)
- After a successful device login, the Adobe "Appropriate Use" banner and passive agreement for "Appropriate Use" must be displayed.
- Password recovery must be disabled.

3.2.3 Physical Device Security

- Devices must be physically secured according to the Physical Security Policy and Restricted Access Authorization Policy. Due to deployment requirements, Wireless Access Points do not need to be in secured data centers or telecommunication rooms, but they must be installed within a cardkey-secured building perimeter and out of easy reach.
- Device consoles can only be connected to a centrally managed console server having restricted access, and must have a console timeout configured.
- Logging and Monitoring must be done according to Security Monitoring Standard and Infrastructure Logging Standard. with the following enhancements unique to the standard
- Logs transmitted across public networks must be protected via encryption, in compliance with Cryptography Standard.
- Devices must be configured to send SNMP v3 traps and sent to approved SNMP trap receivers for infrastructure monitoring parameters.
- Security Devices must be configured according to Security Device Configuration Requirements and manage changes according to Change Management Standard

3.2.4 Network and Logical Security Segmentation

- Networks or server workloads must be segmented into the smallest practical units to reduce attack surface, minimize lateral movement, and maintain separation between production and non-production environments.
- Security Zones*:* Adobe data center networks must be placed into security zones with defined connectivity at the perimeter of each zone. Refer to Data Center Segmentation Guidelines to understand how data centers are segmented.
- Containerized workloads may be protected by a centrally managed logical firewall service instead of a physical firewall under the following conditions:
  - Container firewall service meets all requirements of this Standard
  - Container workloads are registered to a centrally managed Service Registry
  - Integration is established with network firewalls so container workloads can be uniquely identified for access control on network firewalls

3.2.5 Security Policy Configuration Requirements

3.2.5.1 *Baseline Rules*: Baseline rules establish default connectivity allowed into and out of each zone. Security Device Owners must document approval from Enterprise Security for initial deployment and any changes to baseline rules.

3.2.5.2 *User Change Requests*: Rules granting access to a specific service or IP address must be requested through a documented and auditable process. *Requests* must be reviewed by a documented risk assessment process and will be rejected if they violate acceptable risk factors. Time-bound access requests must have expiration dates that are enforced by Security Device Owners.

3.2.5.3 *Security rule cleanup*: Security Device Owners must monitor rule usage and remove any rules that have not been used in the past year. Rules that can be correlated with Service Catalog entries should be automatically removed when their associated services are decommissioned.

3.2.5.4 *Restrictions* for *Embargoed Territories:* Subject to review by Adobe's Legal department and in compliance with the trade laws of the United States and other national governments, Adobe must restrict access to users or entities in embargoed countries. The list of embargoed countries can be found here. Guidance on technical measures can be found here.

NOTE*:* In some instances, for enterprise customers, not end users, blocking access for embargoed countries may not be required because those businesses may have the legal right to collect data from individuals within embargoed territories. For questions, please contact Trade Compliance.

3.2.5.5 Restricted and Confidential data security zones must be configured to deny traffic inbound or outbound by default and to allow inbound or *outbound* traffic by exception only to provide the minimum necessary services. For example, if a port for SFTP is open but not in use, it must be closed.

3.2.6 Partner Network Connections

3.2.6.1 Third-party network connections via LAN-to-LAN VPN or private network must be routed through a security device configured for least privilege access. Each third party must be configured in its own security zone.

3.2.6.2 Third-party network connections require a Vendor Security Review (VSR) prior to connection. See the Vendor Information Security Standard for detailed requirements.

3.2.6.3 Third party network connections must have an expiration date aligned with the expiration date of the agreement with that company, and no longer than 3 years. Expiration dates for these connections may be extended with proof of an updated agreement.

3.2.7 Requirements Specific to Cardholder Data Environments

Environments containing Cardholder Data must adhere to all the above requirements, including the requirements mentioned in this section. Other environments are not required to adhere to the requirements in this section.

- Inventory must be reduced to the minimum possible level.
- Documentation must be maintained for security features that are implemented for insecure protocols.
- Permitted ports, protocols, and services must be inventoried and validated.
- A DMZ must be used to restrict incoming connections from the internet to front-end servers.
- Environments containing Cardholder Data must be in a segregated environment.
- Cardholder Data network environments must be limited to authorized personnel and must practice the principles of least-privilege. See requirements in Logical Access Account Standard.
- Dynamic packet filtering must be enabled on the network.

3.3 Requirements Specific to FedRAMP Environments refer to FedRAMP Environment Protection Standard

3.4 Requirements Specific to Cardholder Environments refer to Cardholder Data Protection Standard

4. Definitions

Term	Definitions
Device Owner	Individual or team accountable for the correct configuration and compliance of a device or set of devices under their management.
Firewall	A network gateway that protects the resources of a private network from other networks with different trust levels or different administrative ownership.
Network Segmentation	Network segmentation is a technique for separating network assets and devices using physical and virtual networking employing technology (for example, but not limited to, firewalls) to control network communications between segments.
Proxy Server	An intermediary server between a client and a server, often placed between networks of disparate trust or control. The proxy server accepts connections from the client and initiates a new connection to the server on behalf of the client. Application-aware proxy servers are a good supplement to network firewalls because they can offer security above the transport layer, whereas network firewalls have limited security intelligence. A reverse proxy is a type of proxy that connects clients from less trusted networks, especially the Internet, to servers in more trusted networks.
Security Zone	A Security Zone is a function as defined on a data center firewall. Each data center zone has a classification and is managed by the firewall and network team.

Term	Definitions
Service Owner (SO)	The Service Owner is accountable for a specific service within an organization. To ensure that a service is managed with a business focus, the definition of a single point of accountability is essential. For more details, refer to the Availability Monitoring Standard
VPN	A Virtual Private Network (VPN) is an encrypted tunnel between network endpoints and/or gateways. A VPN provides confidentiality, authentication, integrity, and non-repudiation, even when it uses an untrusted network such as the Internet for transport. VPNs are usually deployed in a client-to-gateway model for remote access and a gateway-to-gateway model for connecting private networks more dynamically and at lower cost than dedicated telecom circuits.
Web Application Firewall (WAF)	A web application firewall (WAF) is an appliance, server plugin, or filter that applies a set of rules to an HTTP conversation. Generally, these rules cover common attacks such as Cross-site Scripting (XSS) and SQL Injection. By customizing the rules to your application, many attacks can be identified and blocked. The effort to perform this customization can be significant and needs to be maintained when the application is modified.

5. Responsibilities

Group	Responsibilities
Device Owners (Network Infrastructure, Security Infrastructure, and Security Operations)	• As described in Section 3.2

6. Governing Policy

Adherence to the governing Policy referenced below is required to be compliant with this Standard:

- Information Security Policy

7. References

The following governance documents can be found on the Technology Policies and Standards Inside Adobe site:

- Availability Monitoring Standard
- Uniform Cloud Security Standard,
- Change Management Standard
- Infrastructure Logging Standard
- Logical Access Account Standard
- Remote Access Standard
- Security Monitoring Standard
- Vendor Information Security Standard
- Vulnerability Management Standard

8. Document Properties

Coordinator	Ensures Review, Approval and Publication; Facilitates Discussions	Zenitha Das (Consultant, Tech GRC)
Driver	Subject Matter Expert; Owner of Content; Works with Contributors	Jason Joy (Security Architect)

Approver	Approves Document; Ultimately Responsible for Execution	Mike Mellor (VP, Cyber Operations) Pete Bigley (Director, Enterprise Architecture) Vibhor Tripathi (Manager, IT Security Operations)
Contributor	Provides Recommendations; Subject Matter Expert; Critical Reviewer	Click here for Contributor list
Informed	Notified of Publications	Click here for Informed list

9. Document History

Version	Approval Date	Changes	Approved By
11.0	April 2024	**No Major Changes** **Minor Changes** • Section 3.1.4 – added a sentence regarding all Ethos environments having the default data classification as Confidential • Section 3.3.4 – added link to Data Classification and Handling Standard • Section 6 – updated the definition of 'Service Owner' • Sections 8 & 9 – added descriptions for the referenced documents • Section 9 – removed documents not referenced in this document and added the ones that are referenced • Minor spelling and grammar fixes • Andy Smith removed from Driver role	Mike Mellor, VP, Cyber Operations Pete Bigley, Director Enterprise Architecture Vibhor Tripathi, Manager, IT Security Operations
12.0	January 2025	**Major Changes** • Section 3 – Restructured entire document to clearly outline responsibilities based on worker type • Merged 'Network Appliance Standard' within this standard **Minor Changes** • Section 3.4 – Transferred content to FedRAMP Environment Protection Standard • Section 3.5 – Transferred content to Cardholder Data Protection Standard • Removed sections related to 'Exceptions' and 'Violations' which will remain in the governing policy	Mike Mellor, VP, Cyber Operations Pete Bigley, Director Enterprise Architecture Vibhor Tripathi, Manager, IT Security Operations